



El Asalto Invisible: El Hackeo Silencioso a Tesla

RA 2.1: Auditoría Linux

Semana 06 • Sesión 01

Estudio de Caso Pericial: Cómo convirtieron clústeres en la nube en minas de criptomonedas

1. 🕵️ El robo que nadie vio venir

Si imaginas a un hacker de película, probablemente piensas en pasamontañas, pantallas con letras verdes que caen en cascada y un rescate millonario en Bitcoin. La realidad corporativa es mucho más irónica y silenciosa. En 2018, intrusos se colaron en los servidores de Tesla alojados en Amazon Web Services (AWS). Pero no entraron para robar planos de autos ni sabotear su software; de hecho, **no borraron ni un solo archivo**.

2. 🚪 La puerta abierta y el parasitismo

¿Cómo entraron? De la forma más vergonzosa: hallaron una consola de contenedores (**Kubernetes**) expuesta a Internet **sin contraseña**. En lugar de activar un ruidoso Ransomware, aplicaron el parásito perfecto: el **Cryptojacking**. Desplegaron scripts para poner los colosales procesadores **Intel Xeon** a minar **Monero** las 24 horas del día, camuflando el tráfico tras Cloudflare para burlar los cortafuegos.

3. 🔥 Servidores con fiebre sin síntomas

En la nube no existen monitores ni ratones; los servidores operan en modo **Headless** (100% consola). Nadie vio pantallas trabadas en la oficina. Pero en los racks, los CPUs ardían al 100%. ¿Cómo los descubrieron? **Por la factura eléctrica y de nube**: el costo de cómputo se disparó a cifras astronómicas. Tesla pagaba la cuenta mientras los atacantes cobraban las criptomonedas.

4. 🛡️ El contraataque pericial del Blue Team

Para cazar la intrusión a ciegas sin interfaz gráfica, los analistas ejecutaron una batería forense directa en la terminal Bash:

- **whoami** e **id**: Verificaron la identidad del proceso en espacio de usuario (**UID 1000**); el intruso no corrompió el núcleo root.
- **uptime**: Reveló un *Load Average* superior a 4.0, probando asfixia total de CPU.
- **lscpu** y **free -h**: Auditaron el silicio secuestrado (núcleos Xeon y memoria RAM).
- **cat /etc/passwd**: Confirmaron que las cuentas de servicio terminaran en **nologin**, descartando usuarios clandestinos interactivos.
- **hostname -I** vs **curl ifconfig.me**: Contrastaron la IP privada (**10.88.0.x**) con la IP pública, rastreando la fuga con **iplocation.io**.

5. 💡 La moraleja pericial

En la nube, **el poder de cómputo y la electricidad son dinero**. Un ciberdelincuente no necesita destruir tus datos si puede convertir tu propio servidor en su cajero automático personal. Moraleja: si dejas la consola sin llave, alguien más usará tus procesadores para volverse millonario.

ORGANIZADOR VISUAL: ANATOMÍA DEL INCIDENTE EN LA NUBE

Evidencia obligatoria: Reproducir en libreta de apuntes con regla

1. VECTOR DE ATAQUE

- **Amenaza**: Cryptojacking silencioso.
- **Brecha**: Kubernetes sin contraseña.
- **Objetivo**: Robo de ciclos de CPU (Monero).
- **Evasión**: Tráfico oculto en Cloudflare.

2. SÍNTOMAS TÉCNICOS

- **Procesador**: 100% de CPU sostenido.
- **Carga**: *Load average* crítico (> 4.0).
- **Modo**: Servidor remoto **Headless** (Debian).
- **Detección**: Alarma en factura mensual AWS.

3. RESPUESTA FORENSE (BASH)

- **Identidad**: **whoami** + **id** (UID 1000).
- **Hardware**: **lscpu** (Intel Xeon) + **free -h**.
- **Sistema**: **cat /etc/passwd** (nologin).
- **Red**: **hostname -I** vs **curl ifconfig.me**.

📝 CUESTIONARIO PERICIAL DE ANÁLISIS (RESPONDER A MANO EN LIBRETA)

1. ¿Por qué el Cryptojacking es mucho más difícil de detectar que un ataque común de Ransomware?
2. ¿Qué grave error de configuración permitió a los intrusos acceder a la infraestructura de Tesla?
3. ¿Qué significa que un servidor Linux opere en modo **Headless** y cómo se administra?
4. ¿Qué diferencia técnica existe entre la IP de **hostname -I** y la entregada por **curl ifconfig.me**?
5. ¿Qué atajos indispensables de teclado utilizará el analista en el editor **nano** para levantar la bitácora?

Acreditación Formativa
Sesión 01 • MTCS-20 • RA 2.1
Lectura + Esquema + Cuestionario

SELLO DOCENTE